Basics of Information Security (4360702)

Semester – 6th

Diploma in Computer Engineering

Prepared By:

Dr. Jaydevsinh Vala

Sr.Lecturer in Computer Engg. Department

A.V.P.T.I, Rajkot

Institute Vision and Mission

- *Vision:*
  - *To cater skilled engineers having potential to convert global challenges into opportunities through embedded values and quality technical education.*
- *Mission:*
  - *M1: Impart quality technical education and prepare diploma engineering professionals to meet the need of industries and society.*
  - *M2: Adopt latest tools and technologies for promoting systematic problem solving skills to promote innovation and entrepreneurship.*
  - *M3: Emphasize individual development of students by inculcating moral, ethical and life skills.*

Department Vision and Mission

- *Vision:*
  - *Develop globally competent Computer Engineering Professionals to achieve excellence in an environment conducive for technical knowledge, skills, moral values and ethical values with a focus to serve the society.*
- *Mission:*
  - *M1: To provide state of the art infrastructure and facilities for imparting quality education and computer engineering skills for societal benefit.*
  - *M2: Adopt industry oriented curriculum with an exposure to technologies for building systems & application in computer engineering.*
  - *M3:To provide quality technical professional as per the industry and societal needs, encourage entrepreneurship, nurture innovation and life skills in consonance with latest interdisciplinary trends.*

Examination Scheme

THEORY MARKS		PRACTICAL MARKS		TOTAL MARKS
ESE	CA	ESE	CA	
70	30 (20 Avg of Two Mid Sem + 10 Micro Project)	25	25	150

Course Outcomes

CO1	Describe fundamentals of information security.
CO2	Demonstrate substitution, transposition technique and symmetric cryptography algorithm.
CO3	Demonstrate the public key encryption with public key cryptography.
CO4	Apply measures to protect the network communication from attacks using firewalls and intrusion detection systems.
CO5	Describe the basics of cyber security, cyber attacks, cyber crime.

Chapter 1
Introduction to Information Security

Topics To be Covered

- Introduction to Information security
- Need of Information Security
- Security Attacks: Active Attacks, Passive Attacks, DoS Attacks
- Security Basics Services: CIA (Confidentiality, Integrity, Availability)
- Security Services
- Security Mechanisms

Introduction to Information Security

- *Information Security is a comprehensive discipline that involves the protection of information from Unauthorized Access, Disclosure, Alteration, Destruction, and Disruption.*

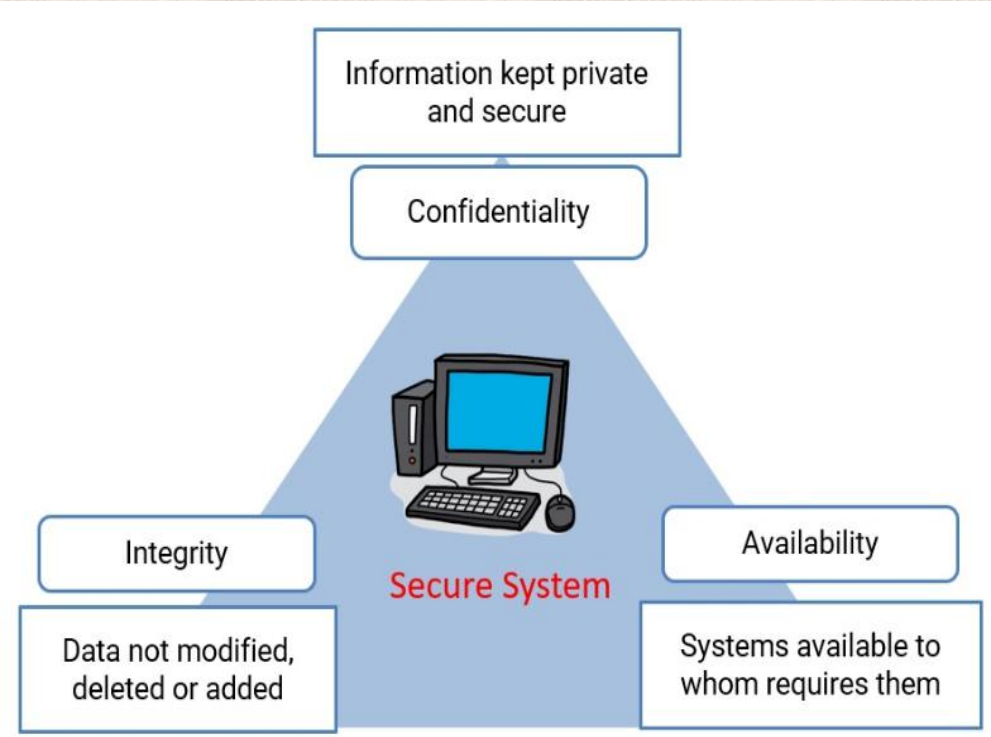
- Primary Goal of information security is to ensure the Confidentiality, Integrity, and Availability of information, as well as other essential services/Principles such as Authenticity, Accountability, and Non-Repudiation.

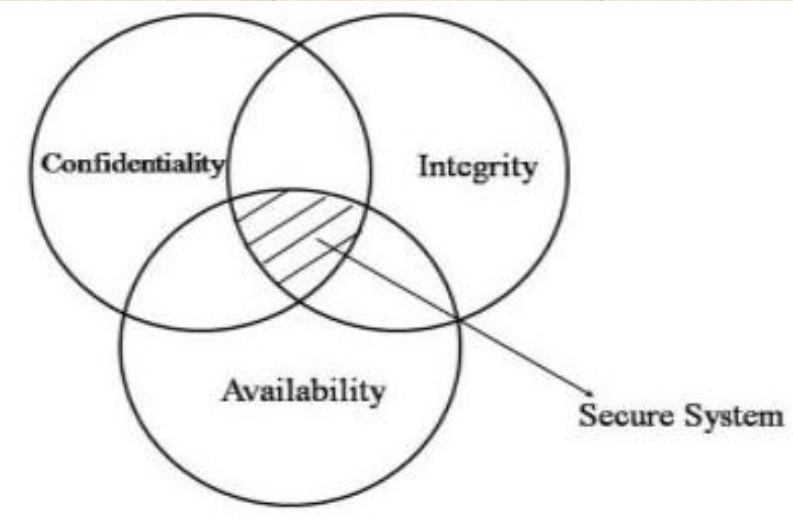
Need of Information Security

- Information Security is essential in today's digital age to protect sensitive data, maintain the confidentiality, integrity, and availability of information, and safeguard against various cyber threats.
- Here are some key reasons highlighting the need for information security.
  - Maintain and Protect Confidentiality, Integrity, Availability.
  - Protection against Cyber Threats.
  - Preserving user privacy
  - Intellectual Property Protection.
  - Protecting Confidential Information.
  - Maintaining Business Continuity.
  - Safeguarding Financial Transactions
  - Protecting Customer Trust.
  - Protecting from Insider Threats.
  - Cloud Security.
  - Protecting Employee Information etc..
  - Etc..

Security Basics Services (CIA Triad)

- Security Basics is a processing or communicating service that can prevent or detect the Security attacks
- Mainly it is known as CIA Triad and that is explained below.





- Confidentiality
  - **Confidentiality Ensures that information is only accessible to authorized individuals or entities.**
  - So an attacker should not be able to read the transmitted data or extract data in case of encrypted data.
  - Objective: Protect sensitive data from unauthorized access.
  - Steps to maintain network confidentiality
    1. Use Strict Authentication
    2. Use Strict Access Control
    3. Ensure Encryption of data
- Integrity
  - **Integrity ensures the accuracy and reliability of information**, It prevents unauthorized modification, alteration, or corruption of data.
  - Hence it Make sure that the message received was exactly the message the sender sent.
  - Objective: Guarantee that information remains unaltered and trustworthy throughout its lifecycle.
- Availability
  - **Availability ensures that information and resources are accessible and usable when needed by authorized users.**
  - Objective: Prevent disruptions, downtime, or denial of service that could impact the availability of critical systems and data.

- Understand CIA Triad with the help of ATM example:
  - In order to better understand how the CIA Triad works in practice; consider the ATM that enables users to access their bank balance and other information.
  - ATMs incorporate the following measures to cover the CIA triad's principles:
    1. Before granting access to sensitive data, the two-factor authentication (debit card with PIN code) ensures confidentiality.
    2. By maintaining all withdrawals and transfers made via the ATM, the ATM and bank software ensure data integrity.
    3. Due to its availability and accessibility, the ATM is available to the general public at all times.

Security Attacks

- Security Attacks refer to malicious actions or unauthorized activities that aim to compromise the confidentiality, integrity, availability, or overall security of computer systems, networks, or data.

Active Attacks

- In Active Attack attacker attempts to alter transmitted data using various way.

- List of Active Attacks:

1. Masquerade
2. Replay
3. Modification of Message
4. Denial of Service (DOS)

Passive Attacks

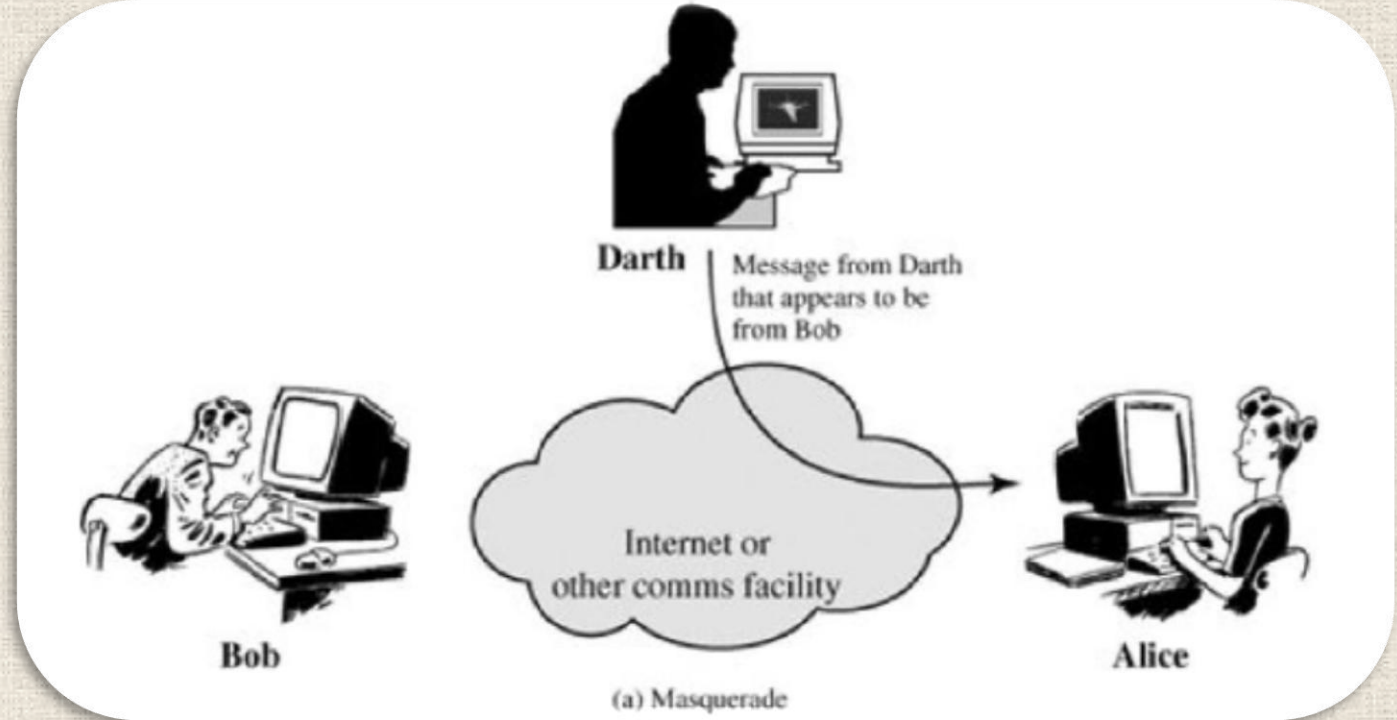
- In passive attack attacker listen conversation or monitors the traffic patterns(in case of encrypted data(and attacking the confidentiality of the data.

- List of Passive Attacks:

1. Release of Messages Content
2. Traffic Analysis

Masquerade Attack

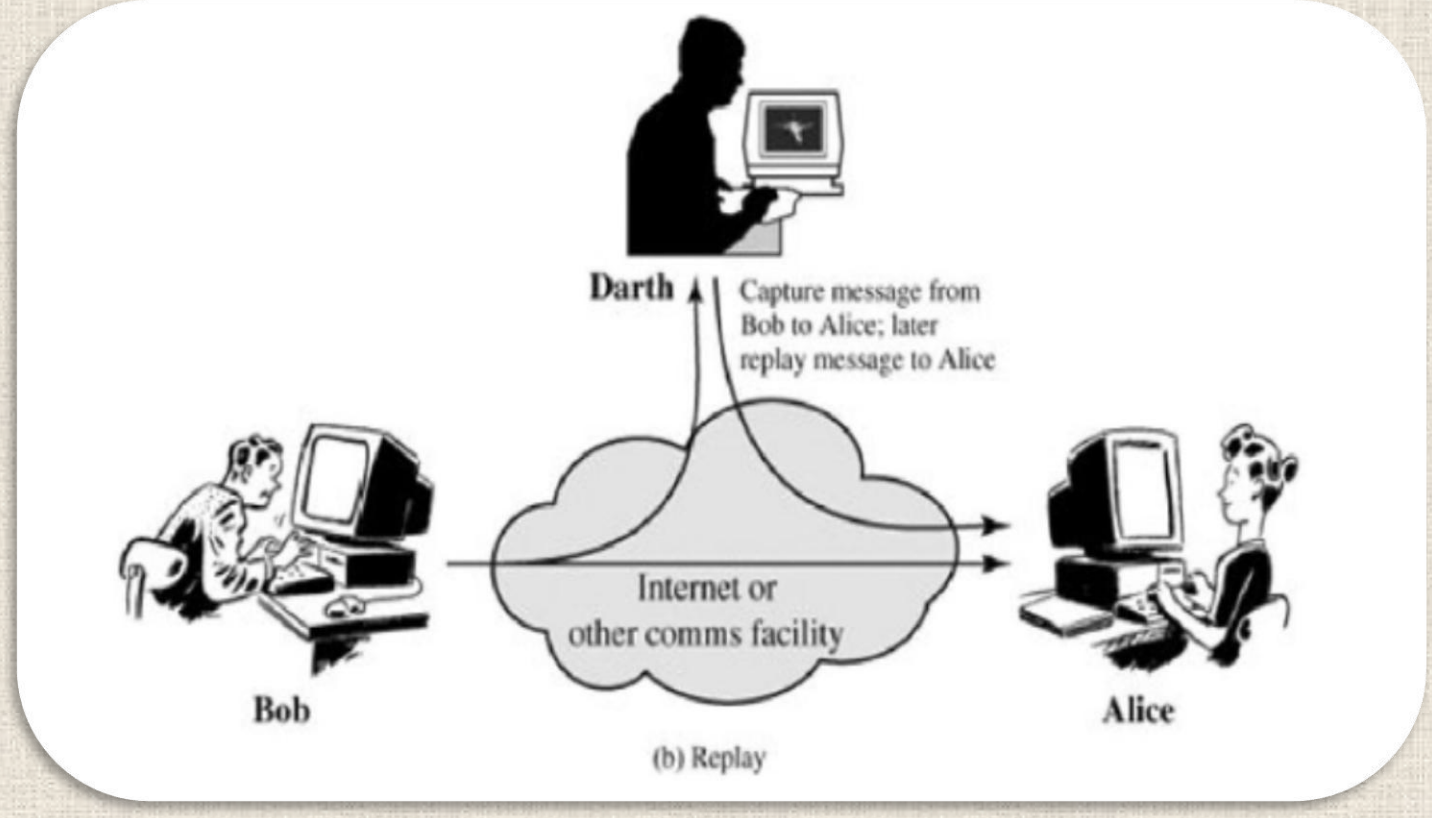
- Masquerade is a type of attack where the attacker **pretends** to be an authorized user of a system in order to gain access to it or to gain greater privileges than they are authorized for, it may be attempted through the use of stolen login IDs and passwords, through finding security gaps in programs, or through bypassing the authentication mechanism.
- Preventive Measures play a vital role in safeguarding against attacks, including the implementation of network monitoring, robust access controls, intrusion detection systems, and the regular maintenance of up-to-date software.



(a) Masquerade

Replay Attack

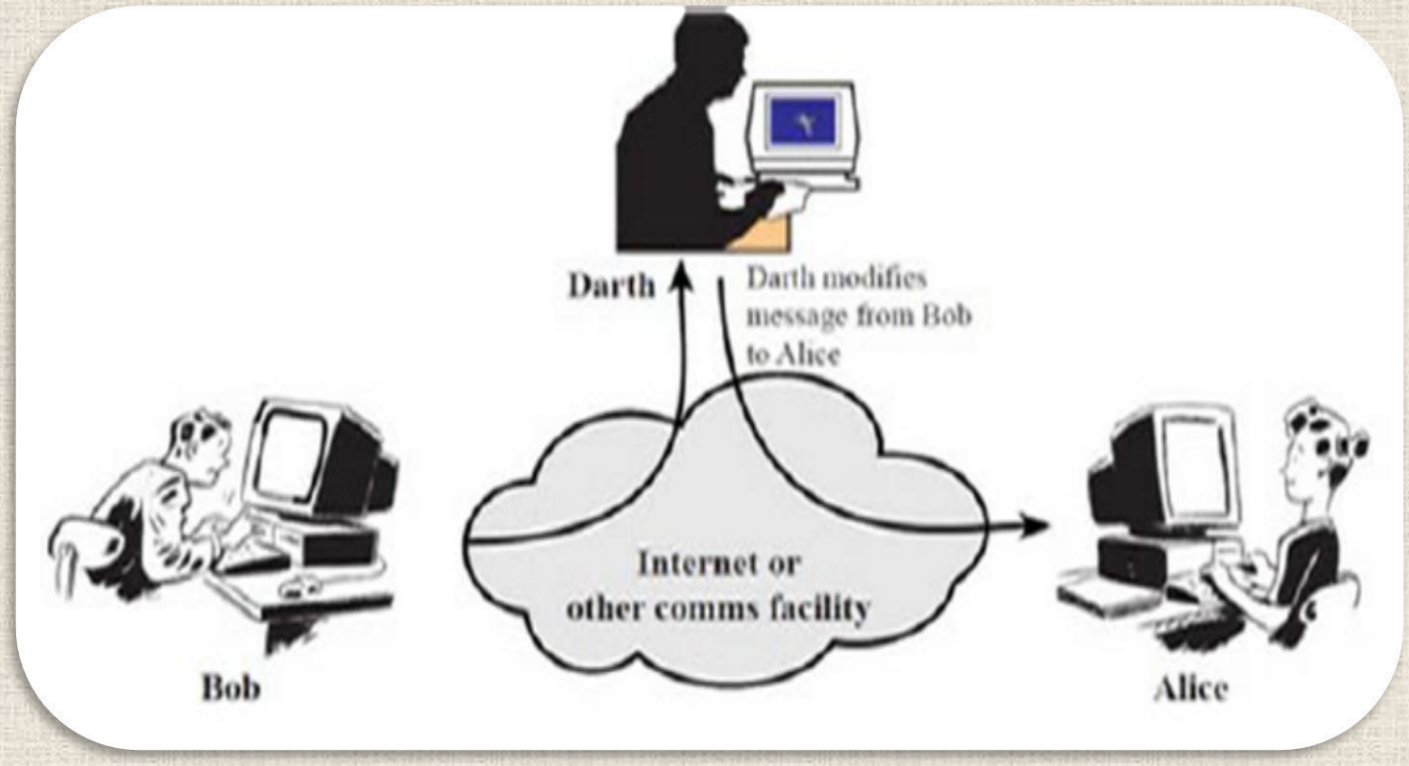
- Replay Attack involves **the passive capture of data unit and subsequent retransmission** is done to produce an unauthorized effect, hence receiver, feeling that it is an authenticated message is deceived because it is actually the message sent by the attacker.
- Here in this example darth capture message that is transmitted from bob to alice, then later the message is retransmitted to alice for unauthorized effect



(b) Replay

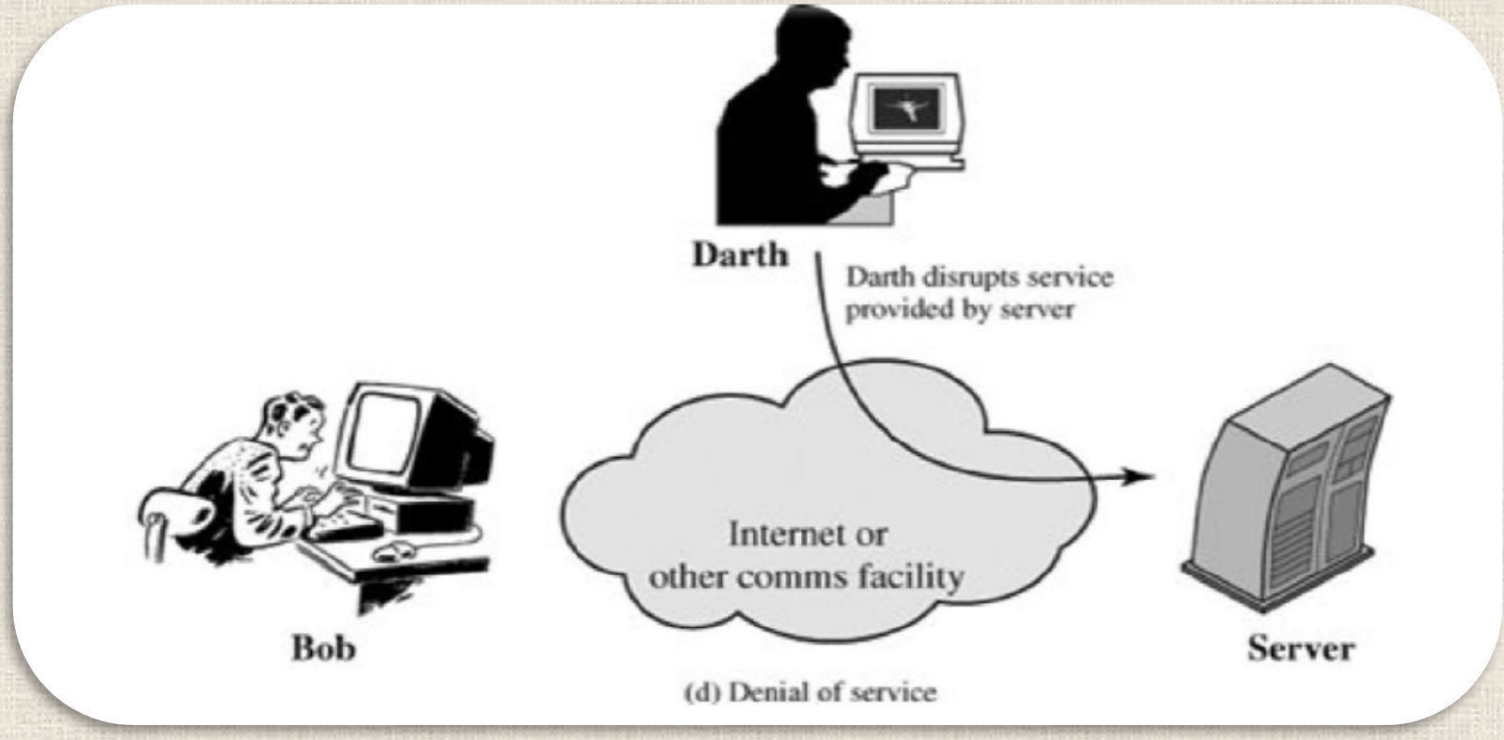
Modification of Messages Attack.

- In Modification of Message Attack, **Some portion of original or legal message is altered,** or that message are delayed or recorded to produced an unauthorized effect.
- Example: Here if Bob send a message that is “Give file access to abc” but darth modifies that message like “Give file access to xyz” and produce unauthorized effect.



Denial of Service (DOS) Attack

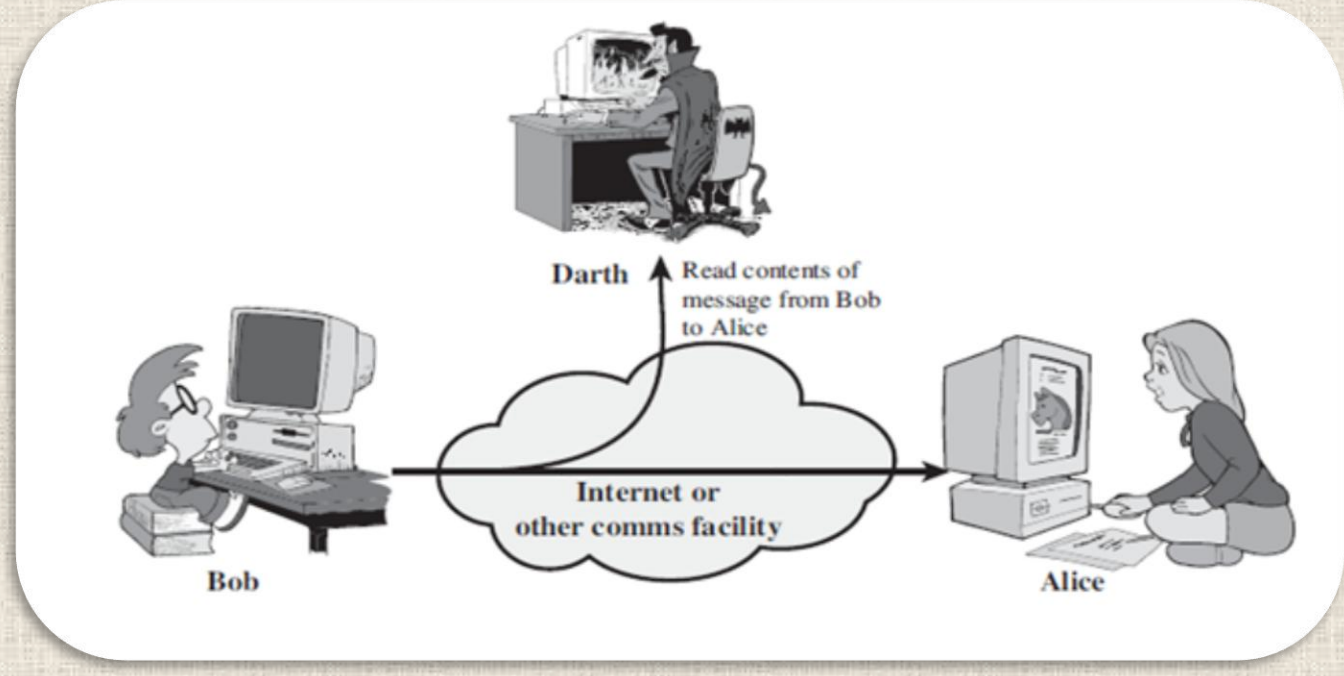
- DOS Attack is designed to make a system or **network unavailable to its intended users by overwhelming it with traffic or requests**, the attacker does this by sending a massive amount of traffic or requests to overwhelm the system's resources so real users can't use it.
- Organization Prevents DoS attacks by using firewalls, setting limits on requests, and spreading traffic with load balancers.
- Here in the figure darth disrupts service which is provided by server.



(d) Denial of service

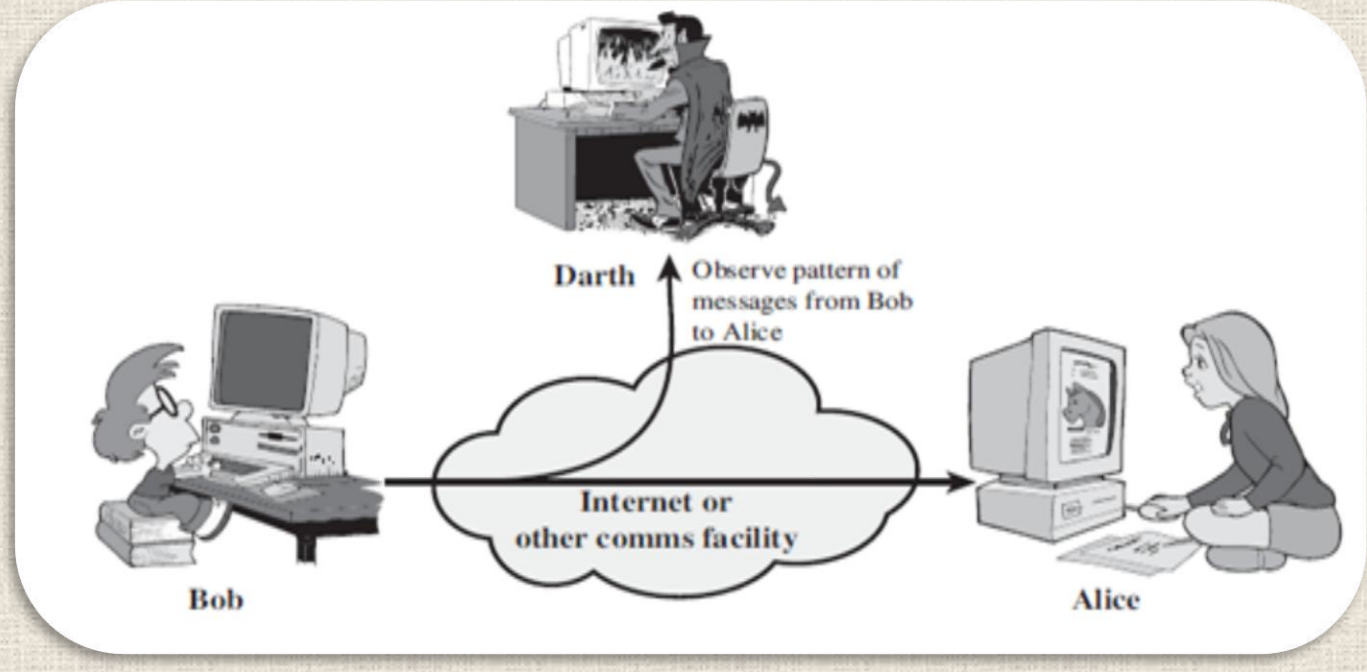
Release of Message Content Attack

- In Release of Message Content **Attack, Attacker read the message which is being transferred from sender to receiver,** Transferred file may contain sensitive or confidential information if the Attacker read it, then it may create harmful effect, So our Aim is prevent an opponent from learning the contents of these transmissions.
- Here in example Darth read the content of message that is transferred between bob and alice.



Traffic Analysis Attack

- Traffic Analysis Attack is the process of intercepting and examining messages in order to conclude information **from patterns in communication**.
- Suppose we communicate using encrypted message, then attacker cannot easily understand the message that are being transmitted, so he/she are trying to understand the pattern of your encryption and then try to decrypt that message.
- Example: here darth observe the patterns of message that is being transferred from bob to alice and then imagine the message on the basis of patterns.



Active Attack vs Passive Attack

Aspect	Active Attack	Passive Attack
Modification of Information	Yes	No
Impact on Integrity and Availability	Poses a danger to both integrity and availability.	Poses a danger primarily to confidentiality.
Harm to the System	Yes	Mostly No
Changes in System Resources	Yes	Mostly No
Detectability	Easy	Difficult
Purpose	To harm the ecosystem.	To learn about the ecosystem.
Duration	Short	Long
Prevention Possibility	High	Low

Security Services

- Security services is a processing or communicating services that can prevent or detect various security attacks.
- X.800 says a security service is like a protective service provided by the different layers of a system when they communicate with each other that helps to ensure that the systems and the data being transferred are secure.
- Here is a list of X.800 Basic security services:
  - Confidentiality
    - Confidentiality Ensures that information is only accessible to authorized individuals or entities, So an attacker should not be able to read the transmitted data or extract data in case of encrypted data.
    - Confidentiality refers to limiting information access and disclosure to authorized users and preventing access by or disclosure to unauthorized ones.
    - Objective: Protect sensitive data from unauthorized access.
    - Steps to maintain network confidentiality
      1. Use Strict Authentication
      2. Use Strict Access Control
      3. Ensure Encryption of data

- Integrity
  - Integrity ensures the accuracy and reliability of information, It prevents unauthorized modification, alteration, or corruption of data, Hence it Make sure that the message received was exactly the message the sender sent.
  - Objective: Guarantee that information remains unaltered and trustworthy throughout its lifecycle.

- Availability
  - Availability ensures that information and resources are accessible and usable when needed by authorized users.
  - Objective: Prevent disruptions, downtime, or denial of service that could impact the availability of critical systems and data.

- Non Repudiation
  - **It is a way to guarantee that the sender of a message cannot later deny having sent the message and that the recipient cannot deny having received the message.**
  - Provides protection against one of the entities from denying all or part of the communication.

- Access Control
  - It is a Prevention of unauthorized use of a resource and also determines who can access information or systems
  - Each entity trying to gain access must first be identified, or authenticated, so that access rights can be tailored to the individual.

- Authentication
  - Authentication Verifies the identity of users or systems to control access to sensitive information, hence Assurance that communicating entity is the one that it claims to be from.

- Here is a list of Extra security services:
  - Cryptography Services
    - Implementing encryption and decryption techniques to secure data during transmission and storage.
  - Firewall Services
    - Implementing network security policies to monitor and control incoming and outgoing network traffic.
  - Intrusion Detection and Prevention Services
    - Monitoring and analyzing network or system activities to detect and respond to security threats or policy violations.
  - Virtual Private Network (VPN) Services
    - Creating secure and encrypted connections over a public network to enable remote access or secure communication.
  - Antivirus and Anti-malware Services
    - Detecting, preventing, and removing malicious software (viruses, worms, trojans) to protect systems from malware threats.
  - Cloud Security Services
    - Implementing security measures for cloud-based platforms and services to protect data and applications in the cloud.

Security Mechanisms

- **Security Mechanisms in information security refers to a specific method, process, or tool implemented to protect computer systems, networks, and data from unauthorized access and various attacks.**
- These mechanisms are designed to enforce security policies and ensure the confidentiality, integrity, and availability of information.
- Here is a list of common security mechanisms:
  - Encryption
    - It is a process of converting plaintext (readable data) into ciphertext (unreadable data) using algorithms and cryptographic keys.
    - Use: **Protects the confidentiality of sensitive data during transmission.**
  - Firewalls
    - A network security device that monitors and controls incoming and outgoing network traffic based on predetermined security rules.
    - Use: **Protects networks from unauthorized access and cyber attacks**.
  - Intrusion Detection Systems (IDS) and Intrusion Prevention Systems (IPS)
    - Monitors network or system activities for signs of malicious behavior and can either detect or prevent intrusions
    - Use: **Identifies and responds to security threats in real-time.**

- Biometric Authentication
  - Using unique physical or behavioral characteristics (such as fingerprints or facial recognition) to verify the identity of individuals.
  - Use: Enhances authentication by ensuring the identity of users.
- Digital Signatures
  - Cryptographic techniques that verify the authenticity and integrity of digital messages or documents.
  - Use: **Ensures the origin and integrity of electronic communications**.
- Digital Certificates
  - Electronically signed statements that verify the identity of an individual, device, Organization or website
  - Use: **Establishes trust in online communications and transactions**.
- Secure Sockets Layer (SSL) and Transport Layer Security (TLS)
  - Protocols that provide secure communication over a computer network.
  - Use: **Encrypts data during transmission to ensure confidentiality.**
- Multi-Factor Authentication (MFA)
  - Requires users to provide two or more forms of identification before granting access.
  - Use: **Enhances authentication security by adding layers of verification.**
- Antivirus Software
  - It is a critical component of information security designed to detect, prevent, and remove malicious software, commonly known as malware.

- Role-Based Access Control (RBAC)
  - Assigning permissions to users based on their roles within an organization.
  - Use: **Access controls to resources based on job responsibilities**.
- Traffic Padding
  - The insertion of bits into gaps in a data stream is called traffic padding, it helps to prevent traffic analysis attacks.
- Hash Functions
  - Algorithms that transform data into a fixed-size string of characters (hash value).
  - Use: Ensures data integrity and it is commonly used in password storage.
- Session Management
  - Controls the creation, maintenance, and termination of user sessions in a secure manner.
  - Use: **Prevents Unauthorized access to active user sessions.**
- Security Policies
  - Formalized rules and guidelines that command how an organization should protect its assets and information.
  - Use: Provides a framework for implementing security measures and ensuring compliance.

Important Questions

Unit-1 (CO-1)	
Sr No.	**Question**
1	Define Information Security.
2	Explain Security Basics (CIA Triad).
3	Define Active Attacks,List Active Attacks,Explain Masquerade Attack in Detail.
4	Define Active Attacks,List Active Attacks,Explain Replay Attack in Detail.
5	Define Active Attacks,List Active Attacks,Explain Modification of Message Attack in Detail.
6	Define Active Attacks,List Active Attacks,Explain DoS Attack in Detail.
7	Define Passive Attacks,List Passive Attacks,Explain Release of Message Content Attack in Detail.
8	Define Passive Attacks,List Passive Attacks,Explain Traffic Analysis Attack in Detail.
9	List Security Services, Explain any Four in Detail.
10	List Security Mechanisams, Explain any Four in Detail.